ISO/IEC 27001:2022

CONFIDENTIAL

Information Security Management System Audit Report

Internal Audit

Acme Financial Services (demo)

Report reference	MN-ISMS-2026-DEMO
Audit period	30 Sept 2026 to 03 Oct 2026
Lead auditor	Marsellino Nasry
Audit team	Lead auditor; technical expert (network and cloud); observer
Version	1.0
Issued	12 Oct 2026

Prepared by Marsellino Nasry, Offensive Security and ISO 27001 Specialist

Contents

1. Document control and scope 3
2. Executive summary 4
3. Methodology and rating criteria 5
4. Management system conformity (Clauses 4-10) 7
5. Annex A control assessment 9
6. Information security risk assessment 10
7. Audit findings 11
8. Control gap register 12
9. Remediation plan 14
10. Approval and sign-off 15

Classification: Confidential. Distribution is limited to the auditee's management and the audit team unless approved by Chief Risk Officer.

MARSELLINO NASRY

1. Document control and scope

Field	Detail
Organization	Acme Financial Services (demo)
Engagement	Demo: pre-certification internal audit
Audit type	Internal Audit
Audit criteria	ISO/IEC 27001:2022 incl. Amd 1:2024; ISO/IEC 27002:2022 for control guidance
Audit period	30 Sept 2026 to 03 Oct 2026
Sites and locations	Head office, Cairo; primary data center; disaster recovery site
Lead auditor	Marsellino Nasry
Audit team	Lead auditor; technical expert (network and cloud); observer
Auditee representative	Chief Information Security Officer
Report reference	MN-ISMS-2026-DEMO
Version	1.0
Approved by	Chief Risk Officer
Classification	Confidential

ISMS scope

The ISMS covers the design, operation and support of the card payment processing platform, including the supporting IT infrastructure, data centers, and the people and processes that deliver these services from the head office and the primary data center.

Exclusions, interfaces and dependencies

Retail marketing operations are out of scope. Interfaces: managed SOC provider (outsourced monitoring), SaaS email and collaboration, and card-scheme networks.

MARSELLINO NASRY

2. Executive summary

86 / 100

Readiness index

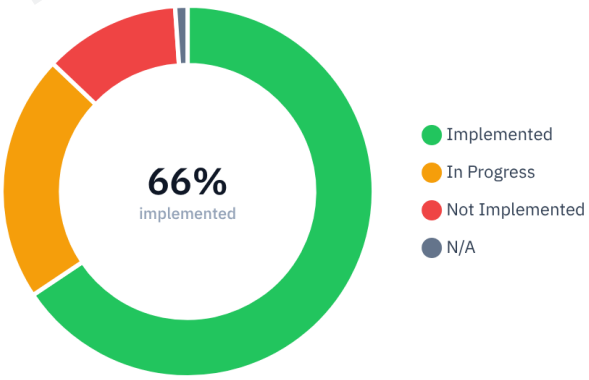
Conditionally ready

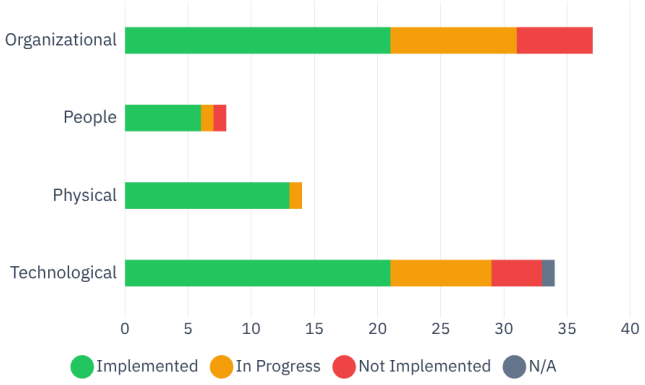
Annex A is 77% implemented (weighted); certification readiness needs 85% or more.

This internal audit assessed Acme Financial Services (demo) against ISO/IEC 27001:2022. Of the 93 Annex A controls, 92 were determined applicable and 1 were excluded. 61 applicable controls (66%) are implemented, 20 are in progress and 11 are not implemented. 25 of 25 management-system requirements were assessed, with a conformity score of 97%. The risk register holds 8 risks, of which 1 remain above the residual risk appetite of 9. Open findings total 5: 0 major and 3 minor nonconformities, 1 observation and 1 opportunity for improvement. The indicative readiness index is 86 out of 100: conditionally ready.

Indicator	Result	Basis
Annex A implementation	66%	61 of 92 applicable controls implemented
Weighted implementation	77%	Implemented 1.0, in progress 0.5
Clause 4-10 conformity	97%	25 of 25 requirements assessed
Average control maturity	2.8 / 5	92 controls rated; target 3
Maturity attainment	82%	Current against target, capped at 100%
Risk treatment coverage	88%	8 risks; residual appetite 9
Risks above appetite	1	Open risks with residual score above appetite
Open nonconformities	0 major / 3 minor	1 observation and 1 OFI also open
Remediation actions	19 open / 2 overdue	Across controls, risks and findings

Annex A implementation overview





MARSELLINO NASRY

3. Methodology and rating criteria

The assessment was performed through interviews with process owners, inspection of documented information and records, observation of operational activities and, where appropriate, re-performance of controls on a judgmental sample. Management-system requirements (Clauses 4 to 10) were rated for conformity. Annex A controls were evaluated for implementation status, maturity against target and operating effectiveness. Conclusions are based on the evidence sampled during the audit period.

Conformity ratings for Clauses 4 to 10

Rating	Definition
Conforming	Requirement fully met; objective evidence confirms effective implementation.
OFI	Requirement met; an opportunity to improve efficiency or effectiveness was identified.
Observation	Requirement met, but a weakness exists that could lead to a nonconformity if not addressed.
Minor NC	Isolated or partial failure to meet a requirement that does not undermine the ISMS as a whole.
Major NC	Absence of, or systemic failure to meet, a requirement, raising significant doubt that the ISMS achieves its intended outcomes.

Control maturity scale

Level	Name	Description
0	**Non-existent**	No control in place.
1	**Initial**	Ad hoc and undocumented; depends on individuals.
2	**Repeatable**	Performed consistently but largely informal.
3	**Defined**	Documented, standardized and communicated.
4	**Managed**	Measured, monitored and reviewed for effectiveness.
5	**Optimized**	Continuously improved and automated where practical.

Risk evaluation criteria

Level	Score (likelihood x impact)	Expected response
Critical	15 - 25	Immediate treatment; escalate to top management
High	10 - 14	Treatment plan with owner and deadline
Medium	5 - 9	Treat, or accept with risk-owner approval
Low	1 - 4	Accept and monitor

Residual risk appetite for this engagement: a residual score of 9 or below may be accepted with risk-owner approval.

Readiness index

MARSELLINO NASRY

The readiness index is an indicative composite: 35% weighted Annex A implementation, 35% Clause 4-10 conformity, 15% risk treatment coverage and 15% maturity attainment. Any open major nonconformity produces a "Not ready" verdict regardless of score. "Certification ready" also requires weighted Annex A implementation of at least 85%, every clause requirement assessed and a populated risk register. The index supports, and does not replace, professional audit judgement.

MARSELLINO NASRY

4. Management system conformity (Clauses 4-10)

Clause	Requirement	Rating	Evidence and auditor notes
4 Context of the organization			
4.1	Understanding the organization and its context	**Conforming**	-
4.2	Understanding the needs and expectations of interested parties	**Conforming**	-
4.3	Determining the scope of the ISMS	**Conforming**	Evidence: ISMS Scope Statement v3.0, approved by the steering committee
4.4	Information security management system	**Conforming**	-
5 Leadership			
5.1	Leadership and commitment	**Conforming**	-
5.2	Policy	**Conforming**	-
5.3	Organizational roles, responsibilities and authorities	**Conforming**	-
6 Planning			
6.1.1	Actions to address risks and opportunities	**Conforming**	-
6.1.2	Information security risk assessment	**Conforming**	-
6.1.3	Information security risk treatment	**Conforming**	Evidence: SoA v2.4; risk treatment plan 2026; residual risk acceptance memo
6.2	Information security objectives and planning to achieve them	**Observation**	Evidence: IS Objectives 2026 v1.1; Q2 KPI report Objectives are defined but four of nine KPIs lack baselines, which limits evaluation of progress.
6.3	Planning of changes	**Conforming**	-
7 Support			
7.1	Resources	**Conforming**	-
7.2	Competence	**Conforming**	-
7.3	Awareness	**Conforming**	-
7.4	Communication	**Conforming**	-
7.5	Documented information	**Conforming**	-
8 Operation			
8.1	Operational planning and control	**Conforming**	-
8.2	Information security risk assessment	**Conforming**	-
8.3	Information security risk treatment	**Conforming**	-
9 Performance evaluation			
9.1	Monitoring, measurement, analysis and evaluation	**OFI**	Evidence: Monthly security dashboard Metrics are reported but not trended over time.

MARSELLINO NASRY

Clause	Requirement	Rating	Evidence and auditor notes
9.2	Internal audit	**Minor NC**	Evidence: Internal audit programme v2.1; Q1 and Q2 audit reports The 2026 audit programme did not cover A.8.20 to A.8.23 in the current cycle.
9.3	Management review	**Conforming**	-
10 Improvement			
10.1	Continual improvement	**Conforming**	-
10.2	Nonconformity and corrective action	**Conforming**	-

MARSELLINO NASRY

5. Annex A control assessment

Theme	Controls	Applicable	Implemented	In progress	Not impl.	Implemented %	Avg maturity
A.5 Organizational	37	37	21	10	6	57%	2.4
A.6 People	8	8	6	1	1	75%	3.0
A.7 Physical	14	14	13	1	0	93%	3.4
A.8 Technological	34	33	21	8	4	64%	2.8
Total	93	92	61	20	11	66%	2.8

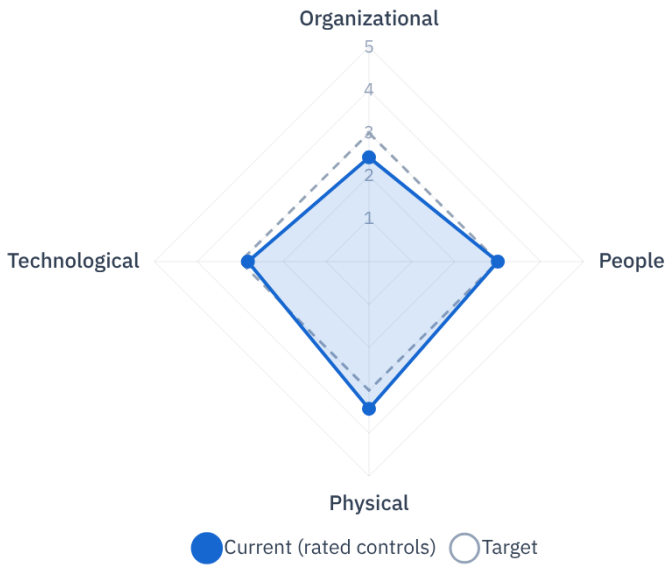
Cybersecurity concept coverage (ISO/IEC 27002:2022 attributes)

Concept	Applicable controls	Fully implemented	Weighted coverage
Identify	22	14	77%
Protect	70	48	78%
Detect	13	5	62%
Respond	11	5	64%
Recover	6	5	83%

Operating effectiveness testing (applicable controls)

Effective	Partially effective	Ineffective	Not tested
53	19	0	20

Maturity profile by theme

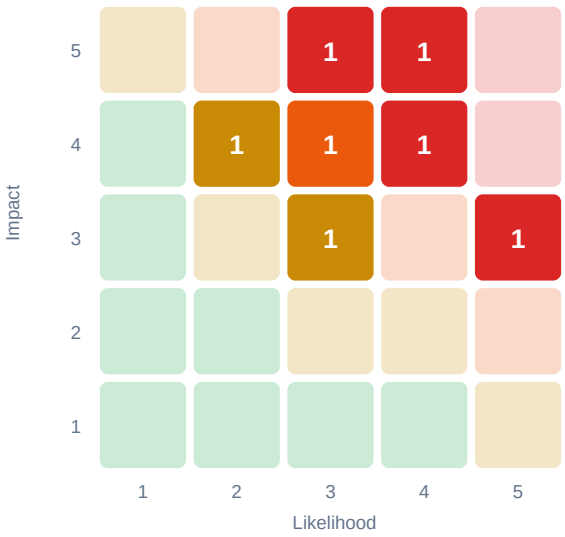


MARSELLINO NASRY

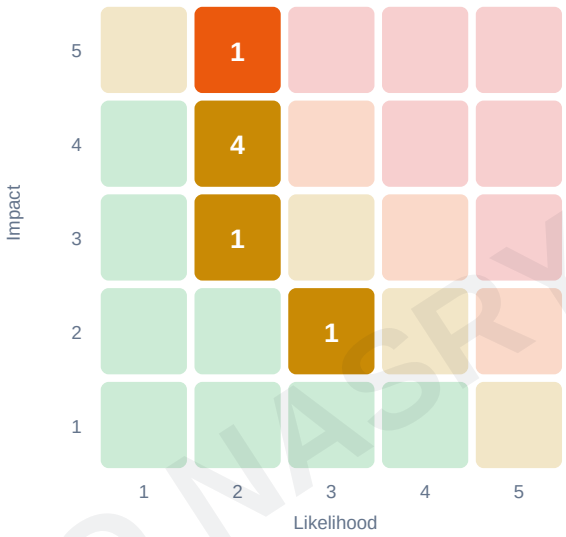
6. Information security risk assessment

8 risks recorded; 7 remain open. Heat maps exclude closed risks. Residual scores above the appetite of 9 require further treatment or formal acceptance by the risk owner.

Inherent risk



Residual risk



Risk register summary

ID	Risk	Owner	Inherent	Treatment	Controls	Residual	Status
R-001	Ransomware encrypts payment processing servers	Head of Infrastructure	**20 Critical**	Mitigate	A.8.7, A.8.8, A.8.13, A.5.24	**10 High**	In Treatment Above appetite
R-004	Compromise of privileged administrator accounts	Head of Infrastructure	**16 Critical**	Mitigate	A.8.2, A.8.5, A.8.15, A.8.16	**8 Medium**	In Treatment
R-002	Exfiltration of cardholder data through email or removable media	CISO	**15 Critical**	Mitigate	A.8.12, A.5.14, A.7.10, A.8.24	**8 Medium**	In Treatment
R-005	Phishing leads to credential theft	CISO	**15 Critical**	Mitigate	A.6.3, A.8.5, A.8.23	**6 Medium**	Open
R-003	Breach at the managed SOC provider exposes monitoring data	Procurement Lead	**12 High**	Transfer	A.5.19, A.5.20, A.5.22	**8 Medium**	Open
R-007	Production personal data used in test environments	Head of Development	**9 Medium**	Mitigate	A.8.11, A.8.31, A.8.33	**6 Medium**	In Treatment
R-006	Extended power failure at the primary data center	Facilities Manager	**8 Medium**	Mitigate	A.7.11, A.8.14, A.5.30	**4 Low**	Closed
R-008	Non-compliance with personal data protection law	Compliance and DPO	**8 Medium**	Accept	A.5.31, A.5.34	**8 Medium**	Accepted

MARSELLINO NASRY

7. Audit findings

ID	Type	Reference	Finding	Owner	Due	Status
F-001	Minor NC	Clause 9.2 Internal audit	The 2026 internal audit programme does not include Annex A controls A.8.20 to A.8.23, so the full ISMS scope will not be audited within the planned cycle.	ISMS Manager	11 Nov 2026	In Progress
F-002	Minor NC	A.8.8 Management of technical vulnerabilities	In a sample of 25 critical vulnerabilities, 6 were remediated after the 14-day SLA set in the Vulnerability Management Standard, with no approved exception.	Head of Infrastructure	02 Nov 2026	Open
F-003	Minor NC	A.5.18 Access rights	The Q2 user access review for the payment switch application was not evidenced.	IT Operations Manager	19 Oct 2026	Pending Verification
F-004	Observation	Clause 6.2 Information security objectives	Four of nine security KPIs have no baseline or target, which limits evaluation of whether objectives are being achieved.	ISMS Manager	26 Nov 2026	Open
F-005	OFI	A.5.7 Threat intelligence	Consider integrating sector ISAC indicators into SIEM detection use cases to make threat intelligence actionable.	SOC Lead	11 Dec 2026	Open

Evidence, root cause and corrective action

ID	Objective evidence	Root cause	Correction and corrective action
F-001	Internal audit programme v2.1; audit reports for Q1 and Q2 2026.	The programme was built from the 2013 control set and was not re-mapped after the transition to the 2022 Annex A. (5 Whys)	Correction: Network controls added to the Q4 audit plan. Corrective action: Re-map the three-year audit programme to all 93 controls and add a coverage check to programme approval.
F-002	Vulnerability scan exports for March to June; patch tickets; Vulnerability Management Standard v1.3.	-	-
F-003	Access review records for Q1 and Q2; interview with the IT operations manager.	The review owner changed roles and the task was not reassigned. (Ishikawa (fishbone))	Correction: Q2 review completed; 3 excess privileges removed. Corrective action: Assign access reviews to roles rather than people, with automated reminders and escalation.
F-004	IS Objectives 2026 v1.1; Q2 KPI report.	-	-
F-005	Threat intelligence procedure; SIEM use-case catalogue.	-	-

MARSELLINO NASRY

8. Control gap register

Control	Title	Status	Maturity	Effectiveness	Owner	Auditor notes
A.5.2	Information security roles and responsibilities	**Not Implemented**	0 / 3	Not Tested	CISO	-
A.5.6	Contact with special interest groups	**Not Implemented**	0 / 3	Not Tested	CISO	-
A.5.8	Information security in project management	**Not Implemented**	0 / 3	Not Tested	CISO	-
A.5.11	Return of assets	**Not Implemented**	1 / 3	Not Tested	CISO	-
A.5.14	Information transfer	**Not Implemented**	0 / 3	Not Tested	CISO	-
A.5.25	Assessment and decision on information security events	**Not Implemented**	0 / 3	Not Tested	SOC Lead	-
A.6.2	Terms and conditions of employment	**Not Implemented**	0 / 3	Not Tested	HR Manager	-
A.8.11	Data masking	**Not Implemented**	1 / 3	Not Tested	Head of Infrastructure	-
A.8.12	Data leakage prevention	**Not Implemented**	0 / 3	Not Tested	Head of Infrastructure	No DLP capability for email, web or endpoints. Card data egress relies on firewall rules only.
A.8.23	Web filtering	**Not Implemented**	1 / 3	Not Tested	Network Manager	-
A.8.34	Protection of information systems during audit testing	**Not Implemented**	1 / 3	Not Tested	Head of Infrastructure	-
A.5.4	Management responsibilities	**In Progress**	2 / 3	Not Tested	CISO	-
A.5.7	Threat intelligence	**In Progress**	2 / 3	Partially Effective	CISO	-
A.5.16	Identity management	**In Progress**	2 / 3	Not Tested	CISO	-
A.5.18	Access rights	**In Progress**	2 / 3	Partially Effective	CISO	Quarterly access reviews completed for core banking. Q2 review for the payment switch was not evidenced.
A.5.23	Information security for use of cloud services	**In Progress**	2 / 3	Partially Effective	CISO	-
A.5.28	Collection of evidence	**In Progress**	2 / 3	Partially Effective	SOC Lead	-
A.5.30	ICT readiness for business continuity	**In Progress**	2 / 3	Not Tested	BCM Manager	-
A.5.32	Intellectual property rights	**In Progress**	2 / 3	Partially Effective	Compliance and DPO	-

MARSELLINO NASRY

Control	Title	Status	Maturity	Effectiveness	Owner	Auditor notes
A.5.33	Protection of records	**In Progress**	2 / 3	Not Tested	Compliance and DPO	-
A.5.34	Privacy and protection of personally identifiable information (PII)	**In Progress**	2 / 3	Partially Effective	Compliance and DPO	-
A.6.5	Responsibilities after termination or change of employment	**In Progress**	2 / 3	Not Tested	HR Manager	-
A.7.6	Working in secure areas	**In Progress**	2 / 3	Partially Effective	Facilities Manager	-
A.8.2	Privileged access rights	**In Progress**	2 / 3	Partially Effective	Head of Infrastructure	-
A.8.6	Capacity management	**In Progress**	2 / 3	Partially Effective	Head of Infrastructure	-
A.8.15	Logging	**In Progress**	2 / 3	Not Tested	SOC Lead	-
A.8.16	Monitoring activities	**In Progress**	2 / 3	Partially Effective	SOC Lead	SIEM operational; 18 of 64 critical servers are not yet forwarding logs.
A.8.20	Networks security	**In Progress**	2 / 3	Not Tested	Network Manager	-
A.8.22	Segregation of networks	**In Progress**	2 / 3	Partially Effective	Network Manager	-
A.8.24	Use of cryptography	**In Progress**	2 / 3	Not Tested	Head of Infrastructure	-
A.8.33	Test information	**In Progress**	2 / 3	Not Tested	Head of Development	-

MARSELLINO NASRY

9. Remediation plan

Due	Source	Action	Owner	State
08 Oct 2026	**Control A.8.8**	Define an exception approval workflow for unpatchable assets	CISO	**Overdue**
10 Oct 2026	**Control A.8.16**	Onboard the remaining 18 critical servers to the SIEM	SOC Lead	**Overdue**
19 Oct 2026	**Control A.5.18**	Complete and evidence the Q2 access review for the payment switch	IT Operations Manager	**Open**
19 Oct 2026	**Finding F-003**	Assign access reviews to roles rather than people, with automated reminders and escalation.	IT Operations Manager	**Open**
26 Oct 2026	**Control A.5.23**	Document shared responsibility matrices for all SaaS and IaaS services	Cloud Architect	**Open**
02 Nov 2026	**Control A.8.8**	Enforce the 14-day SLA for critical vulnerabilities with automated escalation	Head of Infrastructure	**Open**
11 Nov 2026	**Control A.5.7**	Subscribe to the sector ISAC feed and map indicators to SIEM use cases	SOC Lead	**Open**
11 Nov 2026	**Finding F-001**	Re-map the three-year audit programme to all 93 controls and add a coverage check to programme approval.	ISMS Manager	**Open**
11 Nov 2026	**Risk R-005**	Monthly phishing simulations, targeted training for repeat clickers, and phishing-resistant MFA.	CISO	**Open**
16 Nov 2026	**Control A.8.2**	Complete PAM onboarding for database administrator accounts	Head of Infrastructure	**Open**
16 Nov 2026	**Risk R-004**	Complete PAM rollout with just-in-time access and session recording; enforce MFA for all administrative access.	Head of Infrastructure	**Open**
21 Nov 2026	**Control A.8.23**	Deploy secure web gateway policy for all users	Network Manager	**Open**
26 Nov 2026	**Control A.8.11**	Mask PAN and national ID fields in the UAT database refresh	Head of Development	**Open**
26 Nov 2026	**Risk R-001**	Deploy EDR to remaining servers, enforce the 14-day critical patch SLA, and keep immutable offline backups.	Head of Infrastructure	**Open**
26 Nov 2026	**Risk R-007**	Introduce masking in the UAT refresh pipeline.	Head of Development	**Open**
01 Dec 2026	**Control A.5.30**	Run a full DR failover test for the payment platform	Head of Infrastructure	**Open**
11 Dec 2026	**Control A.8.12**	Select and pilot DLP for email and endpoints in Finance	CISO	**Open**
11 Dec 2026	**Risk R-002**	Pilot DLP for email and endpoints; block unapproved removable media.	CISO	**Open**
10 Jan 2027	**Risk R-003**	Add security and right-to-audit clauses at renewal; require an annual ISO/IEC 27001 certificate and SOC 2 report.	Procurement Lead	**Open**

MARSELLINO NASRY

10. Approval and sign-off

This report reflects conditions observed during the audit period, based on the evidence sampled. Audits are sample-based and cannot guarantee that every nonconformity has been identified. Findings should be addressed through the organization's corrective action process, and their effectiveness verified at the next audit.

LEAD AUDITOR	AUDITEE REPRESENTATIVE	APPROVED BY
Marsellino Nasry	**Chief Information Security Officer**	**Chief Risk Officer**
Signature	Signature	Signature
Date	Date	Date

MARSELLINO NASRY